Lab 3 — IPsec/IKE Fingerprinting và Shadow VPN

Vai trò: Network Security Engineer (Blue Team)
Thời lượng khuyến nghị: 2–3 giờ
Môi trường: Labtainers, Ubuntu, 5 container, 2 subnet

1. Mục tiêu

Sau bài này, bạn có thể quan sát dấu hiệu IKE trên UDP 500, NAT-T trên UDP 4500 và ESP (IP protocol 50); phân biệt dấu hiệu IPsec với các luồng HTTP/HTTPS/DNS/SSH/SMTP; đối chiếu endpoint với chính sách gateway tin cậy; điều chỉnh detector; và đánh giá công cụ trên PCAP nền cùng PCAP có tunnel.

Đây là lab quan sát lưu lượng trong mạng sandbox của bài học. Không dùng cấu hình hoặc khóa trong lab cho hệ thống thực.

2. Sơ đồ logic

Máy	Địa chỉ	Vai trò
client1	10.0.1.100	Người dùng bình thường, không cấu hình IPsec
client2	10.0.1.101	Người dùng kiểm thử hai phiên IPsec
gateway	10.0.1.1 / 10.0.2.1	Router, điểm capture và phân tích
ipsec-gw	10.0.2.10	Corporate IPsec gateway, IKEv2
shadow-ipsec	10.0.2.30	Gateway bên ngoài không nằm trong trust policy, IKEv1

`client-net` là `10.0.1.0/24`; `external-net` là `10.0.2.0/24`. Gateway nối hai mạng. Trong kịch bản mẫu, NAT được áp dụng có chọn lọc cho kết nối đến một endpoint nhằm tạo tình huống NAT-T; phiên shadow còn lại được cấu hình để có thể quan sát ESP protocol 50. Phải xác nhận điều này từ capture thật, không suy đoán chỉ từ tên dịch vụ.

3. Bước 1 — Khởi động và khám phá

Trong terminal của VM Labtainers:

```
labtainer vpn-fingerprint_ipsec-shadow
```

Trên VM host, kiểm tra các container đang chạy:

```
docker ps
```

Sau đó trong container `gateway`:

```
ip -br addr
ip route
ping -c 2 10.0.2.10
ping -c 2 10.0.2.30
ping -c 2 10.0.1.100
ping -c 2 10.0.1.101
```

Ghi lại interface gắn với từng mạng, bảng route và trạng thái reachability. Nếu tên interface khác dự kiến, dùng IP thực tế trong `ip -br addr` để xác định interface trước khi bắt gói.

4. Bước 2 — Trạng thái strongSwan

Trên `ipsec-gw`:

```
sudo ipsec statusall
sudo ip xfrm state
sudo ss -ulnp | grep -E ':(500|4500)\b' || true
```

Lặp lại trên `shadow-ipsec`. Trên server có thể daemon đang chạy nhưng chưa có CHILD_SA; điều đó không đồng nghĩa với việc tunnel đã thiết lập. Ghi lại IKE version được cấu hình, trạng thái daemon và trạng thái SA.

5. Bước 3 — Capture baseline trước IPsec

Đảm bảo trên `client2` chưa có kết nối VPN được thiết lập:

```
sudo ipsec statusall
```

Trên `gateway`, chạy capture (giữ terminal này mở):

```
sudo timeout 120 tcpdump -ni any -s 0 -U \
  -w /home/ubuntu/baseline_no_ipsec.pcap
```

Trong lúc capture đang chạy, chạy trên `client1`:

```
./traffic-generator.sh normal 80
```

Và trên `client2`:

```
./traffic-generator.sh normal 80
```

Đợi `timeout` tự dừng. Xác minh PCAP có dữ liệu:

```
ls -lh /home/ubuntu/baseline_no_ipsec.pcap
tshark -r /home/ubuntu/baseline_no_ipsec.pcap \
  -T fields -e frame.number | tail -n 1
```

Nếu số gói chưa đủ cho việc phân tích, tăng số vòng traffic generator và bắt lại. Baseline phải được chụp trước khi chạy `ipsec up`.

6. Bước 4 — Khởi động daemon và kiểm tra cổng

Trên cả `ipsec-gw` và `shadow-ipsec`:

```
sudo ipsec start
sudo ipsec statusall
sudo ss -ulnp | grep -E ':(500|4500)\b' || true
```

Nếu service đã chạy, không cần start lại; hãy ghi nhận trạng thái. Port listener chỉ cho thấy daemon đang lắng nghe, chưa chứng minh rằng có phiên được thiết lập.

7. Bước 5 — Thiết lập hai phiên trên client2

Trên **container `client2`**. Hai connection được chia thành `/etc/ipsec.d/legit.conf` (IKEv2) và `/etc/ipsec.d/shadow.conf` (IKEv1), được nạp qua `include` trong `/etc/ipsec.conf`.

```
sudo ipsec start
sudo ipsec up corp-authorized
sudo ipsec up shadow-vpn
sudo ipsec statusall
sudo ip xfrm state
sudo ip xfrm policy
```

Ghi lại phiên nào thành công, IKE version, địa chỉ peer, SPI và trạng thái CHILD_SA. Không tiếp tục sang capture tunnel nếu các lệnh báo xác thực thất bại hoặc SA chưa được cài vào kernel.

Lưu ý: kịch bản được cấu hình để một peer dùng IKEv2 và peer còn lại dùng IKEv1. NAT-T là hành vi được thương lượng; không coi việc có port 4500 là bằng chứng duy nhất cho mọi gói ESP, và không giả định NAT-T sẽ xuất hiện nếu cấu hình đường mạng đã bị thay đổi.

8. Bước 6 — Capture traffic khi tunnel hoạt động

Trên `gateway`:

```
sudo timeout 150 tcpdump -ni any -s 0 -U -w /home/ubuntu/with_ipsec.pcap
```

Trong thời gian capture, trên **client2** (khi terminal capture ở gateway vẫn đang chạy) tạo lại handshake để PCAP chứa IKE trên UDP 500, rồi phát dữ liệu trong cả hai tunnel:

```
sudo ipsec down corp-authorized || true
sudo ipsec down shadow-vpn || true
sudo ipsec up corp-authorized
```

```
sudo ipsec up shadow-vpn
sudo ipsec statusall
./traffic-generator.sh vpn 100
```

Trên **client1** tiếp tục sinh traffic bình thường:

```
./traffic-generator.sh normal 60
```

Đợi capture hoàn thành rồi kiểm tra kích thước và số frame:

```
ls -lh /home/ubuntu/with_ipsec.pcap
tshark -r /home/ubuntu/with_ipsec.pcap \
  -T fields -e frame.number | tail -n 1
tshark -r /home/ubuntu/with_ipsec.pcap -Y 'ip.proto == 50' \
  -T fields -e frame.number | wc -l
tshark -r /home/ubuntu/with_ipsec.pcap -Y 'udp.port == 500' \
  -T fields -e frame.number | wc -l
tshark -r /home/ubuntu/with_ipsec.pcap -Y 'udp.port == 4500' \
  -T fields -e frame.number | wc -l
validate-pcaps.sh
```

`with_ipsec.pcap` phải được tạo từ traffic thực sau khi SA hoạt động. Lệnh `validate-pcaps.sh` yêu cầu mỗi PCAP có ít nhất 500 frame và PCAP thứ hai phải có UDP 500, UDP 4500 lẫn ESP protocol 50. Nếu protocol 50 không xuất hiện, hãy kiểm tra lại XFRM policy, NAT-T, capture interface và các request đã đi qua tunnel hay chưa. Không dùng gói tự tạo để thay thế ESP thật.

9. Bước 7 — Phân tích bằng tshark, Zeek và Scapy

UDP 500 / UDP 4500 / ESP

```
tshark -r with_ipsec.pcap -Y 'udp.port == 500' -T fields \
  -e frame.time -e ip.src -e ip.dst \
  -e udp.srcport -e udp.dstport -e frame.len
tshark -r with_ipsec.pcap -Y 'udp.port == 4500' -T fields \
  -e frame.time -e ip.src -e ip.dst \
  -e udp.srcport -e udp.dstport -e frame.len
tshark -r with_ipsec.pcap -Y 'ip.proto == 50' -T fields \
  -e frame.time -e ip.src -e ip.dst -e frame.len \
  -e esp.spi -e esp.sequence
```

Kiểm tra tên dissector hiện có:

```
tshark -G protocols | grep -Ei \
  'ISAKMP|IKEv2|Encapsulating Security Payload|ESP'
```

Sau đó xác định display filter IKEv1/IKEv2 mà bản tshark đang cài hỗ trợ. Các bản Wireshark thường dùng `isakmp` cho IKEv1 và `ikev2` cho IKEv2, nhưng hãy xác nhận bằng `tshark -G protocols` thay vì dựa vào tên filter không kiểm chứng.

Quan sát phần payload ESP

```
tshark -r with_ipsec.pcap -Y 'ip.proto == 50' -x -c 1
python3 /home/ubuntu/esp_scapy_inspect.py /home/ubuntu/with_ipsec.pcap
```

Bạn có thể thấy các trường header như SPI và sequence number, nhưng payload ứng dụng của ESP đã mã hóa. Không suy ra nội dung HTTP bên trong chỉ từ bản capture ở router nếu router không phải endpoint giải mã.

Zeek

```
zeek-run.sh /home/ubuntu/baseline_no_ipsec.pcap \
  /home/ubuntu/zeek_logs/baseline
zeek-run.sh /home/ubuntu/with_ipsec.pcap \
  /home/ubuntu/zeek_logs/with_ipsec
find /home/ubuntu/zeek_logs -maxdepth 2 -type f -name '*.log' -print
```

Zeek có thể ghi `conn.log`, `dns.log`, `http.log`, `ssl.log` tùy những giao thức thực sự nhìn thấy trong PCAP. Không mặc định yêu cầu `ike.log` và `esp.log` xuất hiện: nếu không có package/script chuyên dụng thì việc thiếu hai log này không chứng minh PCAP không chứa IPsec.

10. Bước 8 — Điều chỉnh detector

Mở `/home/ubuntu/detect_ipsec.py`. Đọc đầu file và chỉ thay đổi các tham số cho phép: `IKE_PORTS`, `ESP_IP_PROTOCOL`, khoảng frame size, số packet tối thiểu và `AUTHORIZED_GATEWAYS` theo chính sách tin cậy của bài. Không dùng cổng hoặc kích thước gói làm bằng chứng duy nhất; hãy so sánh với endpoint và nhiều lớp dấu hiệu.

Chạy trên `gateway` để phân tích trực tiếp và lưu output minh chứng:

```
cd /home/ubuntu
python3 detect_ipsec.py baseline_no_ipsec.pcap
python3 detect_ipsec.py with_ipsec.pcap
```

Sau khi đã chỉnh whitelist, chạy các wrapper có output riêng để Checkwork thu đúng artifact:

```
detect-baseline.sh
detect-tunnel.sh
evaluate-ipsec.sh
validate-pcaps.sh
```

Đối chiếu địa chỉ gateway, lớp giao thức, số gói khớp rule và nhãn phiên. Lưu output làm minh chứng cho báo cáo.

11. Bước 9 — Đánh giá và trả lời câu hỏi

Chạy trên `gateway`:

```
python3 evaluate.py
# Wrapper có tên artifact riêng dùng cho Checkwork
evaluate-ipsec.sh
```

Script đánh giá presence/absence của shadow VPN ở cấp **PCAP** bằng TP/FP/TN/FN, Precision, Recall, F1 và Accuracy. Nó không phải đánh giá từng packet và không xác nhận đầy đủ tính đúng đắn của mọi nhãn phiên. Ghi rõ giới hạn này trong báo cáo.

Câu hỏi thảo luận:

1. Tại sao cần xem cả UDP 500, UDP 4500 và ESP protocol 50? Mỗi lớp có thể bị bỏ sót trong trường hợp nào?
2. Những đặc trưng nào giúp phân biệt IKEv1 và IKEv2, và tên dissector nào được bản tshark của bạn hỗ trợ?
3. Vì sao nội dung ESP không hiển thị payload ứng dụng? Thông tin metadata nào vẫn quan sát được?
4. NAT-T làm thay đổi cách đóng gói ra sao? Vì sao rule chỉ dựa trên port 500 có thể bỏ sót traffic?
5. Whitelist IP giúp gì và không giải quyết được gì? Hãy thảo luận IP thay đổi, NAT/proxy, gateway hợp pháp bị xâm nhập và việc xác minh danh tính thiết bị.
6. Trong kết quả của bạn, có dấu hiệu nào cho thấy hai phiên khác nhau thay vì chỉ hai chiều của cùng một phiên?

12. Gợi ý ba tầng

- **Gợi ý nhẹ:** Bắt đầu bằng lọc theo port và protocol; so sánh baseline với PCAP có tunnel.
- **Gợi ý vừa:** Kiểm tra cả hai chiều, SPI/sequence và `ip xfrm state` trên endpoint; xác minh frame thực tế trên đúng interface.
- **Gợi ý mạnh:** Kết hợp dấu hiệu protocol với peer IP, trust policy và hành vi NAT-T. Đo precision/recall trên tập capture cụ thể và ghi lại false positive/false negative do rule của bạn tạo ra.

Không có một ngưỡng packet-size hoặc packet-count phổ quát cho mọi mạng; các tham số ở đầu script là giá trị thí nghiệm cần được biện minh bằng capture và chính sách.